

Policy

POL-ACC — Access Control Policy

Version 2.0.0 · approved · classification internal

Document id	POL-ACC
Type	Policy
Status	approved
Version	2.0.0
Classification	internal
Owner	Information Security Officer / ISMS Manager (Alex Rossi)
Approver	Managing Director (Dana Weber)
Effective date	2026-09-01
Last reviewed	2026-08-20
Review cycle	1 year
Next review	2027-08-20
Applies to	all entities in scope
Annex A controls	A.5.15, A.5.16, A.5.17, A.5.18, A.8.2, A.8.3, A.8.5, A.8.18
ISO/IEC 27001 clauses	—
Related documents	STD-AUTH, PROC-JML, POL-CLS, POL-SDLC, POL-PHY, POL-SUP, POL-LOG, POL-CRYP

Digital signature. When this PDF is produced by the release pipeline it carries a PAdES signature of the ISMS document-control key, shown at the bottom of this page; verify it with `isms verify` or any PDF reader. An unsigned copy is not a controlled document.

Digital signature (PAdES) — applied by the release pipeline. An unsigned copy is not a controlled document.

Digitally signed by
ISMS Document Control - UNTRUSTED DEVELOPMENT KEY
2026-08-20 22:09:18 CEST
UNTRUSTED DEVELOPMENT KEY - not a controlled copy

Purpose

Access to PaketPort's backend, fleet-management plane, corporate systems and the personal data of locker users is the most frequently attacked path into the service. This policy defines how logical access is granted, used, reviewed and removed so that every person, service and device has exactly the access its role requires — and loses it when the need ends. It treats risks R-004 (unauthorised access via weak authentication or stale accounts) and R-010 (insider misuse of privileged access) and satisfies the access-control conditions of the cyber insurance and of the carrier agreements.

Scope

All entities in the ISMS scope, all employees, contractors, field-service subcontractors and suppliers with access, and all systems: the cloud backend and its data stores, the fleet-management and OTA signing service, source repositories and CI/CD, corporate identity and endpoints, software-as-a-service tools, network equipment and the locker edge devices. Physical access is governed by POL-PHY; access to source code additionally by POL-SDLC.

Policy statements

Principles

- **ACC-1** Every person, service and device that accesses PaketPort systems shall have a unique identity. Shared accounts are prohibited except the break-glass accounts defined in ACC-13.
- **ACC-2** Access rights shall follow least privilege and need-to-know and shall be assigned through roles derived from the person's job, entity and location. Nobody receives access because of seniority or convenience.
- **ACC-3** Access shall be denied by default and granted only on a documented request approved by the line manager and the owner of the system or information (see PROC-JML). Approvals and grants shall be recorded in the ticket system.

Identity life cycle — joiners, movers, leavers

- **ACC-4** Accounts shall be created only for people with a valid employment or contract record maintained by the HR Manager or, for external parties, a sponsor under ACC-14, and only after the person has acknowledged POL-AUP.
- **ACC-5** When a person changes role or entity, the IT Operations Lead shall re-evaluate all access rights within five working days and remove rights that the new role does not require.
- **ACC-6** When a person leaves, all access — accounts, tokens, keys, VPN and SaaS — shall be disabled by the end of the last working day, and immediately for involuntary terminations. Assets shall be returned in line with POL-CLS.
- **ACC-7** Access rights shall be reviewed by the system owner: privileged access quarterly, all other access at least every six months. Deviations found in a review shall be corrected within ten working days and the review shall be attested in the ticket system.

Authentication

- **ACC-8** Authentication shall meet STD-AUTH. Multi-factor authentication shall be used for all remote access, all privileged access and all access to systems holding personal data. The factors used for privileged access and for the fleet-management plane shall be phishing-resistant, and SMS and voice codes are not permitted as a factor for any account.
- **ACC-9** Authentication information is personal. It shall not be shared, written down in clear text, reused across PaketPort and private services, or stored outside the approved password manager and secrets vault. Suspected compromise shall be reported immediately under POL-IR.

Privileged access

- **ACC-10** Privileged access shall use separate administrative identities, shall be elevated just in time for a limited period, shall require multi-factor authentication, and every privileged session shall be logged to the central log store under POL-LOG.
- **ACC-11** The use of privileged utility programs and direct access to production data stores shall be restricted to named roles, performed through the bastion with session recording, and justified by a change or incident ticket.

Service accounts, secrets and devices

- **ACC-12** Every service account shall have an owner role and a documented purpose. Secrets shall be held in the secrets vault, rotated at least annually and whenever a person with knowledge of them leaves. Locker edge devices shall authenticate with per-device identities and mutually authenticated TLS as defined in POL-CRYP.

Break-glass accounts

- **ACC-13** Break-glass accounts for emergency access shall be sealed, monitored and used only when normal privileged access is unavailable. Their use shall trigger an alert, shall be reviewed by the ISMS Manager within one working day, and their credentials shall be rotated after each use.

Third-party and subcontractor access

- **ACC-14** Access for suppliers, carriers and field-service subcontractors shall be sponsored by an internal role, limited to the systems and data the contract requires, time-limited to at most twelve months per grant, protected by multi-factor authentication and removed when the contract ends. German field-service subcontractors shall access only the maintenance tooling, each technician with a personal account.

Restriction of access to information

- **ACC-15** Access to information shall follow its classification under POL-CLS. Personal data of locker users shall be accessible only to roles with a documented processing purpose, and production data shall not be used in development or test environments (POL-SDLC).
- **ACC-16** Access to source code and build pipelines shall follow POL-SDLC; the ability to sign firmware shall be restricted to the release role and protected by hardware-backed keys.

Roles and responsibilities

Role	Responsibility
Information Security Officer / ISMS Manager	Owns this policy, reviews break-glass use, monitors review completion and MFA coverage
IT Operations Lead	Runs the identity provider and the joiner-mover-leaver process for corporate systems; executes ACC-4 to ACC-7
Head of Platform & SRE	Owns access to the cloud backend, the fleet-management plane and production data; runs the privileged access reviews for those systems
Software Engineering Lead	Owns access to source repositories, CI/CD and firmware signing
System and information owners	Approve access requests and attest the periodic reviews for their systems
Line managers	Approve requests for their staff and notify HR and IT of role changes and departures on the day they are decided
HR Manager	Maintains the employment records that gate account creation and triggers leaver processing
Country Manager Germany	Sponsors subcontractor access for the German field service and confirms its removal at contract end

Compliance and exceptions

Compliance is monitored through the completion rate of access reviews, the share of accounts protected by multi-factor authentication, the number of rights removed in reviews without a documented approval, and the internal audit programme. Exceptions — for example a legacy system that cannot enforce multi-factor authentication — shall be requested through a control exception request, approved by the ISMS Manager and the owner of the affected system, accompanied by compensating controls, time-limited to at most twelve months and recorded in the exception register.

Related documents

- STD-AUTH — Authentication and Password Standard
- PROC-JML — Joiner, Mover and Leaver Access Procedure
- POL-CLS — Asset Management and Information Classification Policy
- POL-SDLC — Secure Development and Change Management Policy
- POL-PHY — Physical and Environmental Security Policy
- POL-SUP — Supplier & Cloud Security Policy
- POL-LOG — Logging and Monitoring Policy
- POL-CRYP — Cryptography Policy

Revision history

Version	Approved	Changes
2.0.0	2026-08-20	ACC-8: the factors used for privileged access and for the fleet-management plane shall be
1.3.0	2025-10-15	ACC-10: just-in-time elevation for privileged access with session logging to the central log store.; ACC-13: break-glass accounts — sealed, monitored, alerting on use, reviewed within one working day.; ACC-7: reviews of privileged access moved from every six months to quarterly following the
1.2.0	2025-04-07	ACC-14: third-party and subcontractor access, covering the field-service subcontractors of; ACC-12: locker edge devices now require per-device identities and mutually authenticated TLS.
1.1.0	2024-11-18	ACC-6: leaver access is disabled by the end of the last working day instead of within 48 hours.; ACC-8: multi-factor authentication extended from remote and privileged access to all systems
1.0.0	2024-04-02	Initial approved version.

Approval and control

Approved by the Managing Director (Dana Weber) on 2026-08-20; owned by the Information Security Officer / ISMS Manager (Alex Rossi). The approval is recorded in version control as the reviewed and merged pull request of this version (PROC-DOC, stage 3).

Source digest sha256:8f96c01d1ee0829b7d819adde4910493a90efc651dff88f8739caa0026f3e31d · rendered by isms-as-code from the repository sources.